

Industrial Security (Bachelor)

Exercise Sheet – Section 09 Standards, Compliance, Governance

Goal. These exercises ask you to apply the standards and regulations from Section 09 to concrete scenarios. You should be able to map a plant or product to the right legal regime (NIS2, KRITIS, CRA, NERC CIP), justify an IEC 62443 Security Level per zone, sketch an asset-owner programme under 62443-2-1, and reason critically about the gap between compliance and security. Cite real identifiers (Directive (EU) 2022/2555, Regulation (EU) 2024/2847, BSI-KritisV, CIP-002 through CIP-014) and real dates throughout. Each question is intended to be answered in 3–10 sentences.

Exercise 9.1 – Which Regulations Apply to a Stuttgart Auto-Parts Factory?

A mid-sized factory in Stuttgart manufactures stamped and welded body parts for a German OEM. The site has 320 employees, runs roughly 40 PLCs and 12 industrial robots, sells exclusively into the EU, and is in the process of launching a connected “smart torque wrench” that uploads telemetry to its cloud. Walk through the decision tree for the four regimes below and decide, with one or two sentences of justification each, whether the regime applies:

- NIS2 (Directive (EU) 2022/2555) – which annex, essential vs. important entity, size thresholds?
- KRITIS (BSI-Kritisverordnung) – does manufacturing of motor-vehicle parts cross a sector threshold?
- CRA (Regulation (EU) 2024/2847) – does the torque wrench qualify as a “product with digital elements”?
- Sector standard IEC 62443 – is it contractual, regulatory, or simply good practice here?

Conclude with a one-sentence answer to the original question: *which regulations apply to us?*

Exercise 9.2 – SL-T Assignment for a 110 kV Substation

A distribution-network operator is rebuilding a 110 kV primary substation feeding 35 000 households. The architecture has four logical zones: *station control* (SCADA gateway, HMI, gateway to the control centre), *protection* (IEC 61850 GOOSE, line and transformer protection IEDs), *engineering* (laptops, IED configuration tools, file servers), and an *iDMZ* (historian replica, remote-access broker). For each zone, assign a target Security Level (SL-T 1–4) and justify the choice in two or three sentences, referring explicitly to (a) consequence of compromise, (b) plausible threat actor, and (c) feasibility on the typical IEDs and gateways available on the market in 2026. State explicitly which zones, if any, you would push to SL-T 4 and which you would deliberately cap at SL-T 2.

Exercise 9.3 – IEC 62443-2-1 Programme Elements

From the Section 09 slides and your reading, IEC 62443-2-1 defines the required elements of an asset-owner Cybersecurity Management System (CSMS). List five required programme elements and, for each, propose one concrete artefact that an auditor could examine to confirm the element exists. The artefacts should be specific (e.g. “Confluence page titled *OT Patch Management Standard v1.3*, dated 2026-02-10, signed off by the OT Security Lead”) rather than generic (“a policy”). Aim for one or two sentences of context per artefact explaining *why* it satisfies that element.

Exercise 9.4 – “62443 Compliant” PLC Vendor Claim

A PLC vendor’s marketing brochure states: “*Our PLC family is IEC 62443 compliant.*” Recall from the slides that a component cannot be “62443 compliant” on its own — it can only be certified against a specific part (typically 62443-4-2) and a specific Security Level. Write down the three questions you would put to the vendor in the next call to test the claim, and explain what answer would count as a pass for each question. Cover at least: scope of certification (which part, which SL), which of the seven Foundational Requirements were assessed and at which SL each was reached, and what evidence (certificate body, issue date, validity) backs the claim.

Exercise 9.5 – NIS2 Article 23 Incident-Reporting Timeline

A ransomware incident is *detected* at the SOC of a German essential entity at 18:30 on Friday, 20 February 2026, and is judged to qualify as a “significant incident” under NIS2 Article 23. Walk through the three reporting deadlines (early warning within 24 h, incident notification within 72 h, final report within 1 month) with the concrete wall-clock date and time by which each must be submitted, and name the recipient in Germany. State explicitly which authority receives the report (BSI as the national CSIRT), and call out at least one practical pitfall (e.g. weekend on-call coverage, language of submission, “without undue delay” interpretation when the incident is detected on a Friday evening).

Exercise 9.6 – C2M2 Self-Assessment of Your Lab

Assess your university OT-security lab against the DOE Cybersecurity Capability Maturity Model (C2M2) in three domains of your choice (e.g. *Asset, Change, and Configuration Management, Identity and Access Management, Incident Response*). For each domain, give yourself an integer score from 0 (*not performed*) to 3 (*managed with measurement*) and justify the score in three sentences citing concrete evidence (or its absence): what artefacts exist, what is informal, what is missing entirely. Conclude with one realistic improvement per domain that would raise the score by one level within a single semester of effort.

Exercise 9.7 – CRA Duties for a Connected-PLC Manufacturer

You work for a vendor that ships a connected PLC — a “product with digital elements” — onto the EU market. Read or recall the structure of Regulation (EU) 2024/2847 (Cyber Resilience Act, signed 23 October 2024). List the three duties from the slides that fall on the manufacturer, give a one-sentence description of each, and state the date by which each duty becomes enforceable (note: most provisions enter force on 11 December 2027, but the vulnerability-reporting duty bites earlier). For each duty, name one piece of evidence that a market-surveillance authority could demand to verify compliance.

Exercise 9.8 – Compliance is Not Security

Compliance is not security. Construct two short scenarios that illustrate this slogan:

1. A plant that is **100 % compliant** with a published checklist (pick one: NERC CIP, IEC 62443-2-1, or NIS2 “appropriate measures”) yet remains demonstrably insecure. Identify the specific control gap the checklist does not catch.
2. A plant that achieves **reasonable security** without ticking every box on a comparable checklist. Identify which boxes it skips and why the residual risk is acceptable.

Write each scenario in two to four sentences. End with one sentence stating what you conclude about how to read checklists.

Exercise 9.9 – NIST CSF 2.0 vs. IEC 62443-2-1

Compare NIST CSF 2.0 (the Govern–Identify–Protect–Detect–Respond–Recover outcomes framework, published February 2024) with IEC 62443-2-1 (the asset-owner CSMS standard) as candidates for the backbone of an OT security programme. In three short paragraphs, address:

- Where the two overlap (functions, vocabulary, deliverables).
- Where they conflict or pull in different directions (audience, prescriptiveness, certifiability).
- Which one you would pick for which audience (board, OT engineering team, external auditor, insurance underwriter).

Exercise 9.10 – Open-Book: KRITIS Energy-Sector Thresholds

Open-book. Look up the current BSI-Kritisverordnung, Anlage 2 (*Energie*), or a reliable English summary thereof. Answer in four to six sentences:

1. What are the current thresholds (in MW, GWh/a, or number of supplied connections) that classify an energy-sector operator as KRITIS?
2. When were these thresholds last lowered, and by which legislative act (cite the version and date)?
3. What concrete consequence does crossing a threshold trigger for the operator (registration with BSI, B3S applicability, incident-reporting duty, audit cycle)?

Cite your source (URL, BGBl. reference, or BSI document title) at the end of your answer.